Hands-On Identity Operations in Microsoft Entra ID

Identity Hygiene · RBAC v2 · Enterprise Applications · Joiner/Mover/Leaver · Access Review · Conditional Access Design · Tenant Hardening · Non-Human Identities · Lifecycle Automation · Credential Clean-up · MFA Support

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Environment	Microsoft Entra ID tenant (Free tier), 36 accounts on 2 Nov 2026; changes made with Microsoft Graph via scripted, ticketed changes
Date	20 October 2026 (Steps 7–9: 28–29 Oct; Step 8b: 2 Nov; Step 10: 5 Nov 2026)
Document Version	1.7
Prepared By	Sabitha S Karanavar
Cost	$0 — every change used Entra ID Free features

1. Purpose and approach

The Week 1 design (scenario, RBAC matrix, OU structure and group naming) was turned into a working, governed identity environment. Every change followed the same controlled pattern: **a script shows a dry run, the change is approved, then applied under a change ticket, and before/after evidence is saved**. Group membership is the single source of truth: application access is derived from groups, so access always follows the approved design.

Step	Work	Ticket	Result
1	Identity hygiene — managers, employee IDs, contractor attributes, disable shared test account	HVMC-IAM-CHG-101	53 changes
2	RBAC v2 — groups that grant exactly the RBAC matrix	HVMC-IAM-CHG-102	13 groups, 45 memberships
3	Simulated enterprise applications with app roles	HVMC-IAM-CHG-103	10 apps, 75 assignments
4	Joiner, mover and leaver	HVMC-JML-201/202/203	3 lifecycle events + 1 finding fixed
5	Quarterly access review	HVMC-AR-2026-Q4	94 lines reviewed, 1 removal
6	Conditional Access design (report-only, licence-gated)	—	13 policies, 13 test cases
7	Free tenant hardening — consent, guests, self-service; break-glass administrators	HVMC-IAM-CHG-106/107	8 settings, Global Admins 1 → 3
8	Non-human identity with certificate credential and least-privilege Graph permission	HVMC-IAM-CHG-108	1 NHI, 3/3 least-privilege tests passed
8b	Lifecycle automation in PowerShell — HR feed and daily leaver check	HVMC-JML-204/205/206	3 events, 16/16 steps ok; leaver removed by the daily check
9	Credential clean-up — reset the passwords exposed in the bulk-create file	HVMC-IAM-CHG-109	30/30 passwords reset, plain-text file deleted

10	MFA support for a lost phone, done by a least-privileged help-desk account	IAM-0004	Verify 6/6

2. Starting baseline (findings)

#	Finding	Why it mattered	Fixed in
F1	No user had a manager	Access reviews and lifecycle approvals need an accountable manager	Step 1
F2	No employee IDs	No link between an account and an HR record (risk R06)	Step 1
F3	One group per department	Secondary access in the RBAC matrix (e.g. doctors reading Pharmacy and LIS) was not grantable	Step 2
F4	Shared test account “Test Nurse - EHR” enabled	Shared account with ePHI access (risk R07)	Steps 1 and 5
F5	Contractor without type, sponsor or end date	Contractor access outlives the contract (risk R06)	Steps 1 and 4
F6	Single Global Administrator	No backup or emergency access (risk R04)	Step 7
F7	Permissive tenant defaults: user app consent, anyone can invite guests	Consent phishing and uncontrolled external access (risk R08)	Step 7
F8	No governed pattern for non-human (workload) identities	Service accounts with shared passwords or broad API permissions are a common breach path	Step 8
F9	Initial passwords of all staff kept in a plain-text bulk-create file (one shown on screen)	Anyone who saw or copied the file could sign in as any staff member	Step 9
F10	Lifecycle changes run by hand, one event at a time; no check that leave dates are acted on	A leaver whose date passes unnoticed keeps access (risk R06)	Step 8b
F11	Bulk-created staff accounts had no hire date	Access reviews and audits cannot see how long access has been held	Step 8b (CHG-110)

3. Step 1 — Identity hygiene

Each department lead became the manager of the department; every staff member received an immutable employee ID (`HVMC-<department code><sequence>`); the contractor was typed, sponsored and given an end date; the shared test account was disabled. The administrator's own account was excluded from automated changes.

Department	Manager (lead)	Reports	Employee IDs
Doctors	**Sarah Chen**	Aisha Rahman, James Okafor, Maria Gonzalez, Peter Novak	HVMC-1001 – HVMC-1005
Nursing	**Angela Brooks**	Emily Carter, Lisa Tran, Monica Alvarez, Noah Fischer, Robert Kim, Tyrone Jackson	HVMC-1101 – HVMC-1107
Pharmacy	**David Patel**	Marcus Webb, Nicole Reyes	HVMC-1201 – HVMC-1203
Laboratory	**Elena Petrova**	Priya Nair, Thomas Wright	HVMC-1301 – HVMC-1303
Human Resources	**Daniel Osei**	Karen Smith	HVMC-1401 – HVMC-1402
Finance	**Brian Adeyemi**	Michael Torres	HVMC-1501 – HVMC-1502
IT	**Kevin O'Brien**	Fatima Ali, Jason Park	HVMC-1601 – HVMC-1603
Security	**Denise Coleman**	Anthony Ruiz	HVMC-1701 – HVMC-1702
Reception	**Grace Nguyen**	Victor Mensah	HVMC-1801 – HVMC-1802

Measure	Before	After
Users with a manager	0	21
Users with an employee ID	0	30
Contractor with type, sponsor and end date	0	1
Shared test account enabled	1	0

Contractor Carlos Diaz: employee ID HVMC-C001, type Contractor, sponsor Kevin O'Brien, contract end 31 Dec 2026 (stored in employeeLeaveDateTime).

4. Step 2 — RBAC v2

New groups follow the Week 1 convention `SG-<Department>-<Application>-<Access>`, one per entitlement in the matrix. A coverage check compares every user's groups with the matrix for their department.

Measure	Before	After
Users whose groups exactly match the RBAC matrix	2/30	30/30
Missing entitlements	45	0
Access beyond the matrix	0	0
SG-* security groups	10	23

New groups: SG-Doctors-Pharmacy-Read, SG-Doctors-LIS-Read, SG-Nursing-Pharmacy-Read, SG-Nursing-LIS-Read, SG-Pharmacy-EHR-Read, SG-Lab-EHR-Read, SG-HR-Payroll-RW, SG-Finance-HRPortal-Read, SG-Finance-FinanceERP-RW, SG-IT-Scheduling-Admin, SG-IT-VPN-Read, SG-Reception-EHR-Read, SG-Contractors-ITAdmin-Limited.

Design decisions (RBAC v2 improves on the Week 1 matrix)

Entitlement held back	Decision and reason
SG-Contractors-EHR-Limited	No Business Associate Agreement on file for the contractor (risk R06) - ePHI access held until signed.
SG-IT-EHR-Read	D1 least privilege / HIPAA minimum necessary: IT staff get no standing ePHI access; break-fix access to be just-in-time.
SG-IT-Pharmacy-Read	D1 least privilege / HIPAA minimum necessary: no standing ePHI access for IT.
SG-IT-LIS-Read	D1 least privilege / HIPAA minimum necessary: no standing ePHI access for IT.
SG-IT-SecurityPortal-Admin	D2 separation of duties: only the Security team administers security monitoring of IT's own actions.

5. Step 3 — Simulated enterprise applications

Each business application from the Week 1 list exists as an app registration and enterprise application with **app roles** for its access levels, **assignment required** (unassigned users are refused), **no secrets or API permissions**, and a homepage on the reserved `.example` domain. Entra ID Free cannot assign *groups* to applications, so a sync script derives *user* assignments from group membership — adding missing ones and removing stale ones — which keeps groups the single source of truth.

Application	App roles	Assignment required	Users
HVMC Electronic Health Record	Read, ReadWrite	Yes	20
HVMC Pharmacy Management System	Read, ReadWrite	Yes	15
HVMC Laboratory Information System	Read, ReadWrite	Yes	15
HVMC HR Portal	Read, ReadWrite	Yes	4
HVMC Payroll System	ReadWrite	Yes	4
HVMC Finance ERP	ReadWrite	Yes	2
HVMC IT Administration Console	Limited, Admin	Yes	4
HVMC Security Monitoring Portal	Admin	Yes	2
HVMC Appointment Scheduling	ReadWrite, Admin	Yes	5
HVMC VPN Portal	Read	Yes	4

6. Step 4 — Joiner, mover, leaver

Group membership is derived from the RBAC v2 matrix; the application sync then follows automatically.

Ticket	Event	Groups before	Groups after	Apps before	Apps after	Account
HVMC-JML-201 Joiner	New hire: Olivia Bennett, Registered Nurse, starts 2026-10-21	—	SG-Nursing-EHR-RW, SG-Nursing-LIS-Read, SG-Nursing-Pharmacy-Read	—	Electronic Health Record, Laboratory Information System, Pharmacy Management System	Enabled
HVMC-JML-202 Mover	Transfer: Noah Fischer, Nursing -> Pharmacy as Pharmacy Technician	SG-Nursing-EHR-RW, SG-Nursing-LIS-Read, SG-Nursing-Pharmacy-Read	SG-Pharmacy-EHR-Read, SG-Pharmacy-PharmacySystem-RW	EHR-Simulated, Electronic Health Record, Laboratory Information System, Pharmacy Management System	EHR-Simulated, Electronic Health Record, Pharmacy Management System	Enabled
HVMC-JML-203 Leaver	Termination: contractor Carlos Diaz, engagement ended early (sponsor Kevin O'Brien)	SG-Contractors-ITAdmin-Limited, SG-Contractors-VPN-Read	—	IT Administration Console, VPN Portal	—	**Disabled**

> **Finding F-JML-01:** F-JML-01 legacy app EHR-Simulated (created 2026-10-12, direct user assignments, not group-driven) kept nurse EHR access after the transfer. **Action:** removed 1 EHR-Simulated assignment(s) for Noah Fischer. The joiner's initial password was random, never displayed or stored, with a forced change at first sign-in; the leaver was disabled and all sign-in sessions revoked before groups were removed, and the account kept (disabled) for audit.

7. Step 5 — Access review HVMC-AR-2026-Q4

Scope: every SG-* membership (which drives application access), direct application assignments, directory roles, Azure RBAC roles and disabled accounts. Reviewers: each user's manager; privileged roles and workload identities: the Security Supervisor; department leads and admin/test accounts: the IAM administrator. HIPAA 45 CFR 164.308(a)(3)(ii)(B)–(C) and (a)(4)(ii)(C).

94	93	1	10
review lines	kept with justification	removed	reviewers

Flag	Lines
None (matches RBAC v2)	75
LEGACY / DIRECT	11
WORKLOAD IDENTITY	5
PRIVILEGED	1
PRIVILEGED - SOLE HOLDER	1
DISABLED ACCOUNT	1

Finding	Decision
Disabled shared test account still held Azure role HVMC-Nurse-EHR-ReadOnly on the ePHI storage account — disabling an account does not remove its roles	Removed (reviewer: Security Supervisor)
Legacy app EHR-Simulated (created 12 Oct) assigned per user, outside group control	Brought under group-driven sync from SG-Doctors-EHR-RW and SG-Nursing-EHR-RW; existing assignments kept for continuity of earlier evidence
Single Global Administrator	Kept; action: two break-glass accounts (done in Step 7)
Microsoft service identities created by Defender/Sentinel onboarding	Kept (platform-managed)

Actions log: Test Nurse - EHR HVMC-Nurse-EHR-ReadOnly on hvmcehrstorage → ok; group-driven app sync (incl. EHR-Simulated) → 1/1 changes applied..

8. Step 6 — Conditional Access design

The tenant runs **security defaults** (confirmed by an AADSTS530035 block on 14 Oct 2026). Conditional Access needs Entra ID P1 (risk policies P2), so the policy set was designed and generated as deployable Microsoft Graph files in report-only state; the deployment script refuses to run without a licence. Full detail: *HVMC_Conditional_Access_Design.pdf*.

ID	Policy	Persona	Licence	Risks
CA001	Global-AllApps-BlockLegacyAuthentication	Everyone	P1	R12
CA002	Admins-AllApps-RequirePhishingResistantMFA	Administrators	P1	R04, R12
CA003	Global-AllApps-RequireMFA	Everyone	P1	R12, R06
CA004	Global-AzureManagement-RequireMFA	Everyone	P1	R02, R15
CA005	Global-ePHIApps-RequireMFAandManagedDevice	Clinical users (EHR, Pharmacy, LIS)	P1 + Intune	R02, R13
CA006	Global-ePHIApps-NoPersistentBrowserOnUnmanaged	Everyone on unmanaged devices	P1	R02
CA007	Contractors-AllExceptAssigned-Block	Contractors	P1	R06
CA008	Contractors-AllApps-MFAEverySession	Contractors	P1	R06
CA009	Global-AllApps-BlockOutsideAllowedCountries	Everyone	P1	R12
CA010	Global-AllApps-BlockDeviceCodeAndAuthTransfer	Everyone	P1	R12
CA011	Global-SecurityInfoRegistration-RequireUSLocationOrMFA	Everyone	P1	R12
CA012	Global-AllApps-HighUserRisk-SecurePasswordChange	Everyone	P2	R12
CA013	Global-AllApps-MediumHighSignInRisk-RequireMFA	Everyone	P2	R12

Rollout: P2 trial → break-glass accounts and US named location → 14 days report-only → IT pilot → everyone (security defaults off) → clinical device policies and risk-based policies. Licence needs: P1: 10 policies; P1 + Intune: 1 policies; P2: 2 policies.

9. Step 7 — Free tenant hardening

Two open risks from the baseline and the access review were closed with free Entra ID settings, using the same dry-run → approval → apply → before/after evidence pattern (`step7_tenant_hardening/tenant_hardening.py`).

Part A — Tenant settings (HVMC-IAM-CHG-106, risk R08)

Users could consent to applications themselves — the route used by **consent-phishing** attacks, where a fake app asks a user for access to mail or files — register apps, create tenants and groups outside the IAM process, and anyone (even guests) could invite guests. All of these now go through administrators. The settings were re-read from the tenant after the change to confirm them.

Setting	Before	After
Who can invite guests	Everyone, including guests	**Admins and Guest Inviter role only**
Guest directory access	limited (default)	**restricted to own object**
Email-verified self-service sign-up	Yes	**No**
Self-service sign-up for subscriptions	Yes	**No**
Users can register applications	Yes	**No**
Users can create security groups	Yes	**No**
Users can create tenants	Yes	**No**
User consent to applications	Allowed (4 consent policies)	**Do not allow user consent**

Part B — Emergency-access (break-glass) accounts (HVMC-IAM-CHG-107, risk R04)

The tenant had a single Global Administrator: a lost phone, a forgotten password or a locked account would have left nobody able to administer HVMC's identities. Microsoft recommends two cloud-only emergency-access accounts. Rather than making a staff member a permanent Global Administrator — which would break the least-privilege decision D2 — two dedicated accounts were created.

Global Administrator	Account
Named administrator	IAM administrator (Sabitha S Karanavar)
Emergency Access	bg-admin-01@<tenant>.onmicrosoft.com
Emergency Access	bg-admin-02@<tenant>.onmicrosoft.com

Control	Implementation
Cloud-only, on the .onmicrosoft.com domain	No dependency on a custom domain, federation or on-premises sync
Strong secret, never displayed	40-character random passwords (~250 bits), written only to a local file readable by the owner; transferred to a password manager / sealed envelope, then the file deleted
No daily use, no other access	No licence, no SG-* groups, no application access; job title marks them as emergency-only
MFA	Security defaults remain on, so each account registers MFA at first sign-in (on a separate authenticator)

Testing and monitoring	Sign-in test every quarter; sign-in logs reviewed after each use (Free tier keeps 7 days of sign-in logs)

10. Step 8 — Non-human identities

Hospital systems talk to each other without a person signing in: an interface engine, a lab system, a backup job. These **non-human identities (NHIs)** often outnumber people and are a common breach path when they use shared passwords, never-expiring secrets or broad permissions. Step 8 inventoried HVMC's NHIs and created the first one using the secure pattern (`step8_nonhuman_identities/nhi.py`, change HVMC-IAM-CHG-108).

Baseline inventory (read-only)

Category	Count	Assessment
User accounts used as service accounts	0	None — matches Microsoft guidance to use workload identities instead
HVMC application service principals	11	No secrets, certificates or API permissions — cannot authenticate on their own
Managed identities	2	Created by Defender for Storage (SecOps lab); probably orphaned since the subscription was disabled — noted for HVMC-AR-2027-Q1
Microsoft / third-party service principals	123	Present in every tenant; no action

The new NHI: HVMC Lab Results Sync

Control	Implementation
Purpose and ownership	Read members of the laboratory groups for the lab results interface. Technical owner: IAM administrator (Sabitha S Karanavar); business owner: Laboratory lead (Daniel Osei)
Identity type	Single-tenant application service principal, tagged HVMC-NHI, ticket in its notes
Credential	X.509 certificate (RSA-2048) issued by **HVMC Issuing CA 1** from the project's own PKI; **no client secret**. Private key kept locally (mode 0600, not in Git), to move into Azure Key Vault
Lifetime	Expires 2027-10-29; rotate by 2027-09-29
Permission	Microsoft Graph **GroupMember.Read.All** (application) only, granted by admin consent
Review	Recorded in the NHI register; reviewed in HVMC-AR-2027-Q1

The NHI then signed in **as itself, with its certificate** (OAuth 2.0 client credentials with a signed JWT assertion). Its token carried exactly one permission (`GroupMember.Read.All`) and the identity type "application". Three calls proved least privilege:

Call made by the NHI	Expected	Result
read members of SG-Lab-LIS-RW	200	HTTP 200 3 members — **PASS**
list all users in the directory	403	HTTP 403 Authorization_RequestDenied — **PASS**
change the description of SG-Lab-LIS-RW	403	HTTP 403 Authorization_RequestDenied — **PASS**

Next for NHIs: move the private key into Azure Key Vault and use a managed identity (instructor-approved, needs an active subscription); a GitHub Actions identity with a federated credential (no secret at all); Workload ID Premium controls (Conditional Access and risk detection for workload identities) documented as a licensed design.

11. Step 8b — Lifecycle automation in PowerShell

In Step 4 each joiner, mover and leaver was a separate scripted change, started by hand (finding F10). Step 8b turns this into a repeatable process driven by the HR system, written in **PowerShell 7 with the Microsoft Graph SDK** — the standard tooling for Microsoft identity administration (`step8b_lifecycle_automation/`).

Part	What it does
HR feed (CSV)	One row per event exported by HR: ticket, Join / Move / Leave, employee ID, department, title, manager, effective date, and an optional end-of-shift time (UTC) for a same-day leaver
Invoke-HvmcLifecycle.ps1	Reads the feed and plans each event from the RBAC v2 matrix (exported to `config/rbac_matrix.json`, so rbac_v2.py stays the single source of truth); shows the plan, and changes nothing without `-Apply`
Invoke-HvmcLeaverCheck.ps1	Daily safety net: deprovisions anyone whose leave date has passed (including disabled accounts still in groups), warns 14 days ahead, flags contractors with no end date
HVMC.Lifecycle.psm1	Shared functions: sign-in, desired groups, user state, plans, evidence

Controls built in

- **Dry run first**, then `-Apply`; evidence (plan, results, before/after) saved for every applied run, with no passwords.
- **Safe to re-run:** an event already in effect is reported as “already done”; a future date is “not due yet”.
- **Separation of duties on transfer:** the old role’s groups are removed *before* the new role’s are added.
- **Admin accounts are never touched**: anyone holding an Entra ID role (the IAM administrator, both break-glass accounts) is excluded.
- **Validation:** employee-ID format, known department, existing groups and manager, unique user name — an invalid row is skipped, not guessed.
- **Joiner passwords** are random, never shown or stored, and must be changed at first sign-in.

Run of 2 November 2026 (HR feed hr_feed_2026-11-02.csv)

Ticket	Employee	Event	Before	After (including the application sync)
HVMC-JML-204	Ethan Morales	Join	no account	Laboratory; groups: SG-Lab-EHR-Read, SG-Lab-LIS-RW; apps: HVMC Electronic Health Record, HVMC Laboratory Information System
HVMC-JML-205	Jason Park	Move	IT; groups: SG-IT-ITAdmin-Admin, SG-IT-Scheduling-Admin, SG-IT-VPN-Read; apps: HVMC Appointment Scheduling, HVMC IT Administration Console, HVMC VPN Portal	Security; groups: SG-Security-SecurityPortal-Admin; apps: HVMC Security Monitoring Portal
HVMC-JML-206	Victor Mensah	Leave	Reception; groups: SG-Reception-EHR-Read, SG-Reception-Scheduling-RW; apps: HVMC Appointment Scheduling, HVMC Electronic Health Record	Last day moved by HR to 2 Nov, access ending 19:30 UTC (end of shift). Removed by the leaver check at 19:35 UTC: account disabled, sessions revoked, groups: none; apps: none

All 16 of 16 steps succeeded: 12 from the HR feed and 4 from the leaver check, whose application sync applied 2/2 changes. Jason Park’s IT administration access was removed before he received the Security portal. HR then moved Victor Mensah’s last day to 2 November, ending at 19:30 UTC (end of shift). The feed only recorded the new leave time, and Victor kept his access until then. The IAM administrator ran the daily leaver check at 19:34 UTC, and it removed his sign-in, sessions, groups and applications within five minutes of his shift ending.

Data fix: hire dates (HVMC-IAM-CHG-110)

The bulk-created staff accounts had no hire date (finding F11); only staff who came through the joiner process had one. `Set-HvmcHireDates.ps1` loaded an HR extract and recorded **30 of 30** hire dates, each re-read to confirm. It fills empty dates only, never overwrites one (a conflict is referred to HR), and skips admin accounts. The dates are **simulated lab data** from a fixed rule: department leads in 2014, later staff by employee-ID order, always a Monday.

Tests

Test	Result
Re-run the same feed	All 4 events “already done” (including JML-201 from 20 October); 0 event(s) with changes, 0 step(s) in total.
Leaver check before the leave time	1 notice for Victor Mensah, nothing changed — access is not removed while someone is still working
Leaver check after the leave time (live, -Apply)	4/4 steps ok; application sync 2/2 changes applied; account disabled, 0 groups, 0 applications
Leaver check run again	No leavers due, none upcoming, no contractor without an end date.
RBAC coverage after the leaver	30/30 active staff fully match the matrix; 0 missing, 0 extra; 0 application assignments pending
Defect found by testing	The first run’s evidence took its “after” snapshot before the application sync; fixed, and the post-sync state re-recorded

*Scheduling: in production the leaver check runs daily as an **Azure Automation** runbook with a managed identity (no stored credential) — planned together with Key Vault once a subscription is active. Until then it is run manually by the IAM administrator.*

12. Step 9 — Credential clean-up (HVMC-IAM-CHG-109)

The 30 staff accounts were created in bulk from a CSV file that held every **initial password in plain text** (finding F9). One of those passwords had been displayed on screen during an earlier working session. A file like this is a common way credentials leak: it gets copied, backed up or shared. Step 9 made every password in that file useless (`step9_credential_cleanup/password_reset.py`), using the same dry-run → approval → apply → evidence pattern.

Check	Result
Dry run	30 accounts in the file found in Entra ID; 0 hold an admin role (the script stops if one does); 1 disabled leaver account
Passwords reset	**30 of 30**, including the disabled leaver, so the old password is dead if the account is ever re-enabled; 0 failures
Administrator accounts	Not touched — the IAM administrator and both break-glass accounts were not in the file
New passwords	16 random characters, all four character classes; generated in memory and **never displayed or logged**; sent to Graph through a temporary file readable only by the owner, not on the command line
Storage	Written straight into a password-protected archive kept on the administrator's workstation, outside the repository; archive tested (opens and holds all rows) before anything was deleted
Old plain-text file	**Deleted** after the archive test passed
Evidence	Who was reset and when, with masked user names and **no passwords**

Lab trade-offs, recorded on purpose. *(1) The new passwords are not forced to change at next sign-in, so the administrator can keep signing in as test staff; in production each user would get a one-time password or a* ***Temporary Access Pass*** *and set their own, and passwordless sign-in would remove the shared secret altogether. (2) The archive uses standard ZIP encryption so it opens on any Mac; it is weak against offline attack, so it never leaves the workstation. A password manager or an AES-encrypted vault (e.g. Azure Key Vault, once the subscription exists) is the target state.*

13. Step 10 — MFA support for a lost phone (ticket IAM-0004)

Board Activity 4. Dr. Sarah Chen (HVMC-1001) lost the phone holding her Microsoft Authenticator. The help desk checked it was really her, signed her out everywhere, removed the lost phone's MFA method, and she registered her new phone herself (`step10_mfa_support/Invoke-HvmcMfaSupport.ps1`, actions Status / Reset / Verify).

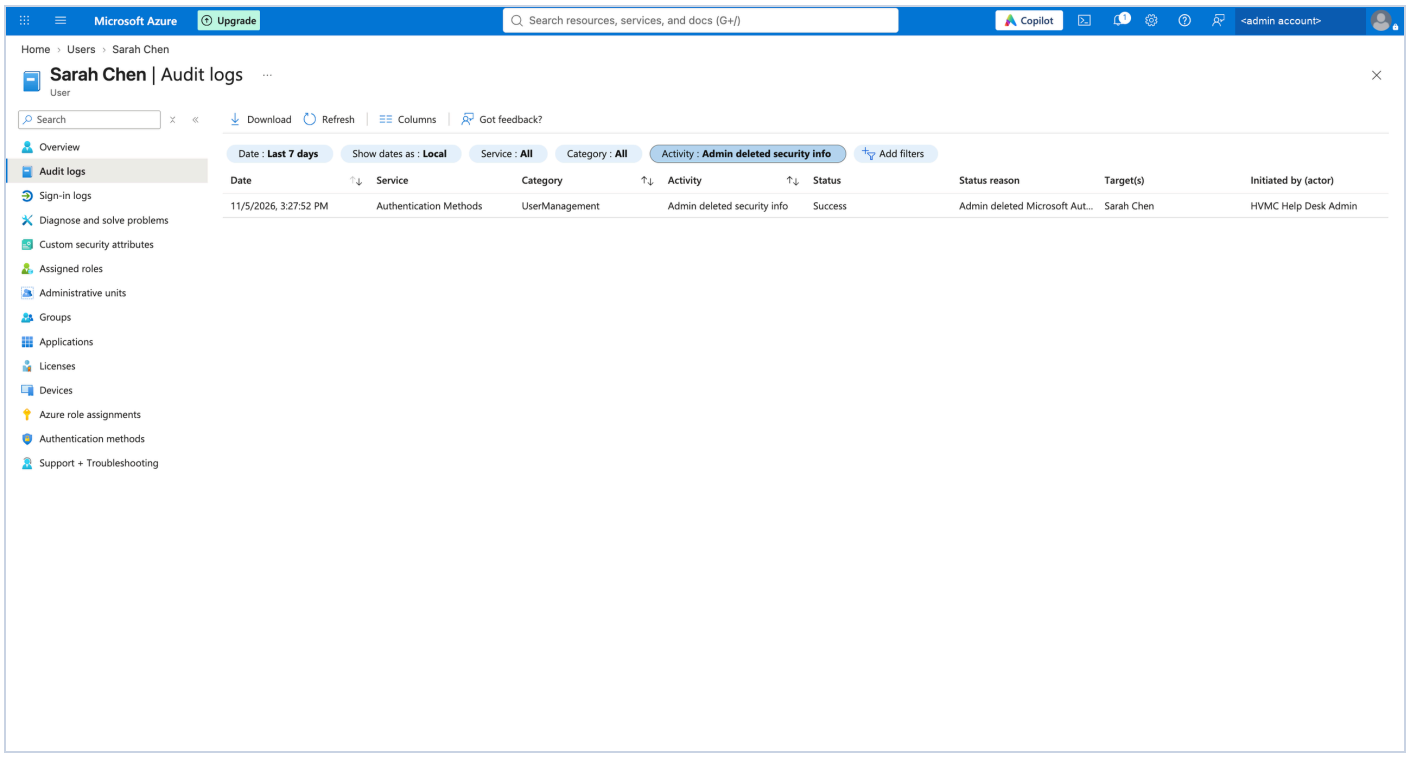
Least privilege: a dedicated help-desk account

The first sign-in attempts with the Global Administrator (a personal Microsoft account) were blocked by **security defaults** (AADSTS530035) for Microsoft Graph PowerShell. Security defaults were kept on. Instead, a help-desk account was created inside the tenant:

Item	Setting
Account	HVMC Help Desk Admin (helpdesk.admin@<tenant>), IT, HVMC-ADM-01, its own Microsoft Authenticator
Roles	**Authentication Administrator** (reset MFA and revoke sessions for non-admin users only) + **Reports Reader** (audit logs)
App approval	Microsoft Graph Command Line Tools approved for **this account only** (consent type Principal) — users cannot approve apps themselves since Step 7
Effect	The Global Administrator only set things up; the reset itself was done by an account that cannot change admins, roles or settings

The run (5 November 2026)

Step	Result
1. Status before	Sarah enabled; 1 MFA method: Microsoft Authenticator on the lost iPhone
2. Identity check	Call-back to the phone number HR has on file — required: the script refuses `-Apply` without `-VerifiedBy`
3. Dry run	Plan shown: revoke all sessions, remove the Authenticator; password and reset e-mail kept; nothing changed
4. Reset (-Apply)	20:27:49 UTC revoke all sign-in sessions: ok; 20:27:52 UTC remove Microsoft Authenticator device: iPhone 12 Pro: ok
5. New phone	Sarah signed in with her password and registered Microsoft Authenticator again (3:52 PM local)
6. Verify	**6/6 checks passed**, including the audit events below
7. Audit log	"Admin deleted security info" by HVMC Help Desk Admin; "User registered security info" by Sarah Chen



Entra audit log: “Admin deleted security info” (Microsoft Authenticator), initiated by HVMC Help Desk Admin — not the Global Administrator.

```
PS /Users/Adult/Downloads/HVMC_IAM_Entra_Handson/step10_mfa_support> ./Invoke-HvmcMfaSupport.ps1 -Action Verify
Connected to Microsoft Graph as helpdesk.admin@<tenant>

IAM-0004  Sarah Chen (HVMC-1001)  sign-in enabled: True
  Registered methods (2):
    Password
    Microsoft Authenticator      device: iPhone 12 Pro
  MFA methods: 1
  Audit events since 2026-11-05 20:26 UTC (26):
    2026-11-05 20:27  Update StsRefreshTokenValidFrom Timestamp success  by helpdesk.admin@<tenant>
    2026-11-05 20:27  Update user                                success  by helpdesk.admin@<tenant>
    2026-11-05 20:27  Update user                                success  by Azure Credential Configuration Endpoint Service
    2026-11-05 20:27  Update user                                success  by Azure Credential Configuration Endpoint Service
    2026-11-05 20:27  Admin deleted security info                success  by helpdesk.admin@<tenant>
    2026-11-05 20:49  Update PasswordProfile                     success  by Microsoft password reset service
    2026-11-05 20:49  Update user                                success  by Microsoft password reset service
    2026-11-05 20:49  Update PasswordProfile                     success  by Microsoft password reset service
    2026-11-05 20:49  Reset user password                        success  by Microsoft password reset service
    2026-11-05 20:49  Update StsRefreshTokenValidFrom Timestamp success  by Microsoft password reset service
    2026-11-05 20:49  Reset password (by admin)                  success  by sabithaskaranavar@<tenant>
    2026-11-05 20:51  Update PasswordProfile                     success  by Microsoft password reset service
    2026-11-05 20:51  Update user                                success  by Microsoft password reset service
    2026-11-05 20:51  Update PasswordProfile                     success  by Microsoft password reset service
    2026-11-05 20:51  Reset user password                        success  by Microsoft password reset service
    2026-11-05 20:51  Update StsRefreshTokenValidFrom Timestamp success  by Microsoft password reset service
    2026-11-05 20:51  Reset password (by admin)                  success  by sabithaskaranavar@<tenant>
    2026-11-05 20:51  Update PasswordProfile                     success  by Microsoft password reset service
    2026-11-05 20:51  Change user password                       success  by Microsoft password reset service
    2026-11-05 20:51  Update StsRefreshTokenValidFrom Timestamp success  by Microsoft password reset service
    2026-11-05 20:51  Change password (self-service)             success  by sarah.chen@<tenant>
    2026-11-05 20:52  Update user                                success  by Azure MFA StrongAuthenticationService
    2026-11-05 20:52  Update user                                success  by Azure MFA StrongAuthenticationService
    2026-11-05 20:52  Update user                                success  by Azure Credential Configuration Endpoint Service
    2026-11-05 20:52  User registered security info              success  by sarah.chen@<tenant>
    2026-11-05 20:52  Update user                                success  by Azure Credential Configuration Endpoint Service

  PASS  identity verified before the reset
  PASS  old MFA methods removed at reset
  PASS  new MFA method registered after the reset
  PASS  audit: admin deleted security info
  PASS  audit: user registered security info
  PASS  account still enabled

6/6 checks passed
```

Verify run: 6/6 checks passed after the user registered her new phone.

Findings

- **Replication delay:** both reset steps returned ok, but a re-check 3 seconds later still listed the deleted method. The script now waits up to 2 minutes and only reports “incomplete” when a step really failed; Verify was adjusted to match.
- **Lab note:** Sarah’s password was also reset by the IAM administrator during the lab because the test password was not at hand. In a real lost-phone case the password is not part of the MFA reset.
- **Next improvement:** a **Temporary Access Pass** issued after the identity check would let the user register the new phone without relying on the password alone.

Ticket: `step10_mfa_support/ticket/Ticket_IAM-0004_MFA_Support.pdf` *(opened 3:25 PM, closed 3:54 PM, 9 figures). Full run log:* `step10_mfa_support/HVMC_Step10_MFA_Support_Run_2026-11-05.pdf`.

14. Results, lessons learned and next steps

Outcome	Evidence
Every active staff member’s access matches the approved RBAC v2 design (30/30 on 2 Nov), with no excess access	Step 2 coverage check, re-run after Steps 4–5 and 8b
Application access is group-driven and self-correcting, including the legacy EHR app	Step 3 sync: 0 additions / 0 removals pending
Joiners, movers and leavers are repeatable, ticketed and evidenced	HVMC-JML-201/202/203 evidence files
Quarterly access review produced decisions, justifications and a removal	HVMC-AR-2026-Q4 decided review pack (Excel)
Zero Trust sign-in policy ready to deploy when licensed	13 report-only policy files + 13 test cases
Tenant defaults hardened and the single-admin risk removed (R04, R08 closed)	Step 7 before/after policy evidence; 3 Global Administrators
First non-human identity built secret-less and proven least-privilege	Step 8 certificate sign-in: 1 allowed call, 2 denied calls
Joiners, movers and leavers run from an HR feed, with a daily leaver check (F10 closed)	Step 8b: 16/16 steps ok; re-run changes nothing; leaver removed 5 minutes after his shift ended
No staff password from the bulk-create file still works (F9 closed)	Step 9: 30/30 reset, file deleted, evidence without passwords
Lost-phone MFA recovery is identity-checked, least-privileged and evidenced	Step 10 / IAM-0004: Verify 6/6; reset done by the help-desk account

Lessons learned

- **Disabling is not deprovisioning:** a disabled account kept an Azure data role until the access review removed it.
- **Unmanaged apps defeat good group design:** a direct-assigned legacy app kept a transferred nurse’s EHR access (F-JML-01).
- **Licences shape the design:** on the Free tier, group-to-app assignment and Conditional Access are unavailable, so automation and documented design fill the gap until a licence is justified.
- **Non-human identities need owners and expiry dates:** a certificate with a rotate-by date and a named owner is reviewable; a forgotten secret is not.
- **Automation must be safe to run twice:** checking the current state first turns a repeated run into “already done” instead of duplicate accounts.
- **Setup files become secrets:** a convenience CSV used once to create accounts kept working passwords for every staff member; clean-up is part of the change.

- **The help desk is an attack path:** an MFA reset without an identity check hands the account to an attacker; the check is the control, and the help-desk account must not be a Global Administrator.
- **Least privilege needs judgement:** following the Week 1 matrix literally would have given IT standing ePHI access; RBAC v2 records why it does not.

Next steps

Action	Cost	Risk
Schedule the daily leaver check (Azure Automation runbook with a managed identity)	Needs an active subscription	R06
Quarterly break-glass sign-in test (next about 28 Jan 2027)	$0	R04
Azure Key Vault for the NHI private key, plus a managed identity (instructor-approved)	Needs an active subscription	NHI
Start the 30-day P2 trial; deploy the 13 policies in report-only; then PIM and native access reviews	$0 (trial)	R04, R12
Domain controller hvmc-dc01 (HVMC.LAN) is built: join client HVMC-CLIENT01 and mirror the 31 identities by script	$0	—

Appendix — change register and files

Ticket	Date	Description
HVMC-IAM-CHG-101	20 Oct 2026	Identity hygiene, 53 attribute/manager/account changes
HVMC-IAM-CHG-102	20 Oct 2026	RBAC v2, 59 group/membership/description changes
HVMC-IAM-CHG-103	20 Oct 2026	Enterprise applications, 85 app/assignment changes
HVMC-JML-201/202/203	20 Oct 2026	Joiner Olivia Bennett, mover Noah Fischer, leaver Carlos Diaz
HVMC-AR-2026-Q4	20 Oct 2026	Access review: 94 lines, 1 removal, legacy app brought under management
HVMC-IAM-CHG-106	28 Oct 2026	Tenant settings: user consent, app registration, tenant and group creation, guest invitations and access, self-service sign-up
HVMC-IAM-CHG-107	28 Oct 2026	Two emergency-access (break-glass) Global Administrator accounts
HVMC-IAM-CHG-108	29 Oct 2026	Non-human identity HVMC Lab Results Sync: certificate credential, GroupMember.Read.All, least-privilege test
HVMC-JML-204/205/206	2 Nov 2026	Step 8b: joiner Ethan Morales, mover Jason Park (IT to Security), leaver Victor Mensah (last day 2 Nov, removed by the leaver check)
HVMC-IAM-CHG-110	2 Nov 2026	Hire dates recorded for 30 staff accounts from an HR extract (simulated lab data)
HVMC-IAM-CHG-109	29 Oct 2026	Credential clean-up: 30 staff passwords reset, plain-text bulk-create file deleted
IAM-0004	5 Nov 2026	MFA support, lost phone (Sarah Chen): help-desk account HVMC Help Desk Admin created (Authentication Administrator + Reports Reader); sessions revoked, Authenticator removed and re-registered; Verify 6/6

Scripts: step1_identity_hygiene/identity_hygiene.py · step2_rbac_v2/rbac_v2.py · step3_enterprise_apps/enterprise_apps.py · step4_jml/jml.py · step5_access_review/build_review_pack.py, apply_decisions.py · step6_conditional_access/ca_design.py, deploy_ca.py · step7_tenant_hardening/tenant_hardening.py · step8_nonhuman_identities/nhi.py · step8b_lifecycle_automation/Invoke-HvmcLifecycle.ps1, Invoke-HvmcLeaverCheck.ps1, Set-HvmcHireDates.ps1 (-Apply) · step9_credential_cleanup/password_reset.py ·

step10_mfa_support/Invoke-HvmcMfaSupport.ps1 (-Apply -VerifiedBy). Each runs as a dry run by default and changes nothing without --apply.